

DOKUMEN ARSITEKTUR JARINGAN DAN PROTOKOL MANAJEMEN KUNCI

IPB SPACE: CAMPUS FACILITY & QUEUE SYSTEM

SPESIFIKASI TOPOLOGI INFRASTRUKTUR CLOUD DAN INTEGRASI ALUR KERJA PROTOKOL AAA



Disusun Oleh (Kelompok 4 - Paralel 1):

- | | |
|---------------------------|---------------|
| 1. Naufal Ghifari Afdhala | (G6401231029) |
| 2. Samuel Christian | (G6401231037) |
| 3. Muhammad Farhadh | (G6401231080) |

**DEPARTEMEN ILMU KOMPUTER
SEKOLAH SAINS DATA, MATEMATIKA, DAN INFORMATIKA
INSTITUT PERTANIAN BOGOR
BOGOR
2026**

INFORMASI DOKUMEN DAN METADATA KEAMANAN INFRASTRUKTUR

Parameter Arsitektur	Spesifikasi Protokol Komunikasi dan Manajemen Kunci
Nama Dokumen Luaran	Architecture_Diagram.pdf (Protokol Manajemen Kunci & Komunikasi)
Lokasi Folder Repo	/02_Design_Documents/Architecture_Diagram.pdf
Format Nama Repo	KOM1315_SmtGenap26_Kelompok04_IPBSpace
Tautan Repositori Git	github.com/ nghifaria/KOM1315_SmtGenap26_Kelompok04_IPBSpace
Tautan Aplikasi (Live)	kom-1315-smt-genap26-kelompok04-ipb.vercel.app
Kredensial Akun Demo	• Super Admin: admin@ipbspace.com (Password: Admin1234) • Facility Manager: manager@ipbspace.com (Password: Manager1234) • Civitas: civitas@ipbspace.com (Password: Civitas1234)
Komponents Infrastruktur	React 19 Client (Vercel), FastAPI Backend Container (Railway), PostgreSQL Managed Cluster (Railway), Appwrite Storage (Cloud), dan SMTP Mailer Gateway
Mekanisme Jalur Transmisi	Enkripsi Saluran HTTPS / TLS 1.3 (Data in Transit), Isolasi Kunci Rahasia Lokal (.env Parameter), dan Private Database Connection Isolation Tunnel
Implementasi Protokol AAA	Bearer Token JWT (Authentication), Dependency Injection Route Guard Layer (Authorization), dan Immutable Audit Trail PostgreSQL Database (Accounting)

Daftar Isi

BAB 1: PENDAHULUAN	4
1.1 Latar Belakang Desain Arsitektur Keamanan	4
1.2 Tujuan Arsitektur dan Manajemen Kunci	4
1.3 Ruang Lingkup Protokol Komunikasi	4
BAB 2: ARSITEKTUR DAN TOPOLOGI KOMUNIKASI SISTEM	5
2.1 Komponen Infrastruktur Aplikasi (Topologi Terdistribusi)	5
2.2 Protokol Komunikasi dan Pengamanan Data dalam Perjalanan (Data in Transit)	5
BAB 3: PROTOKOL MANAJEMEN KUNCI DAN KRIPTOGRAFI	7
3.1 Isolasi Kunci Rahasia Sesi Informasi (.env & config.py)	7
3.2 Protokol Manajemen Kunci Enkripsi Kolom AES-256	7
3.3 Manajemen Kunci Hashing Kredensial Pengguna (Password Hashing)	7
BAB 4: INTEGRASI ALUR KERJA PROTOKOL AAA (ALUR UTAMA)	9
4.1 Visualisasi Runtunan Aliran Protokol AAA Terintegrasi	9
4.2 Alur Aliran Autentikasi (Authentication Workflow)	9
4.3 Alur Aliran Otorisasi Peran (Authorization via RBAC Guard)	10
4.4 Alur Aliran Akuntansi Aktivitas (Accounting & System Audit Log)	10
BAB 5: RANCANGAN TANDA TANGAN DIGITAL DAN OFFLINE VERIFICATION	11
5.1 Dasar Kriptografi RSASSA-PSS	11
5.2 Alur Penerbitan Tiket Digital QR Code	11
5.3 Alur Verifikasi Sisi Lapangan (Offline-Capable Verification)	11
BAB 6: MATRIKS KRITERIA PENERIMAAN (ACCEPTANCE CHECKLIST)	13

BAB 1: PENDAHULUAN

1.1 Latar Belakang Desain Arsitektur Keamanan

Membangun platform sistem informasi berskala besar di lingkungan kampus dengan volume transaksi padat seperti **IPB Space** memerlukan sebuah cetak biru arsitektur jaringan dan infrastruktur yang tidak hanya andal dalam memproses data operasional bisnis, melainkan juga tangguh dalam mempertahankan integritas data dari interseptasi pihak luar. Ketiadaan dokumentasi arsitektur komunikasi yang terenkripsi dan terisolasi secara baku dapat memicu terjadinya celah kesalahan konfigurasi (*security misconfiguration*). Risiko ini meliputi terbukanya port biner basis data relasional ke jaringan publik internet atau tidak terenskripsinya jalur komunikasi data sensitif.

Oleh karena itu, diperlukan perancangan dokumen arsitektur dan spesifikasi protokol keamanan komunikasi yang jelas berbasis prinsip **Security by Design**. Langkah ini diambil untuk memastikan setiap komponen infrastruktur saling memvalidasi parameter tingkat kepercayaan (*trust level*) dan menerapkan penegakan hak akses minimum (*least privilege*) secara otomatis di lingkungan produksi cloud.

1.2 Tujuan Arsitektur dan Manajemen Kunci

Penyusunan dokumen arsitektur ini bertujuan untuk memetakan secara granular jalur komunikasi antar-komponen platform IPB Space serta menspesifikasikan mekanisme pengelolaan parameter rahasia sistem (*cryptographic secret keys*). Melalui visualisasi topologi dan batasan perimeter ini, sistem menjamin pemenuhan tiga pilar utama keamanan informasi: kerahasiaan (*confidentiality*) data profil civitas, integritas (*integrity*) berkas digital proposal permohonan, serta ketersediaan (*availability*) layanan antrean dari ancaman eksploitasi eksternal.

1.3 Ruang Lingkup Protokol Komunikasi

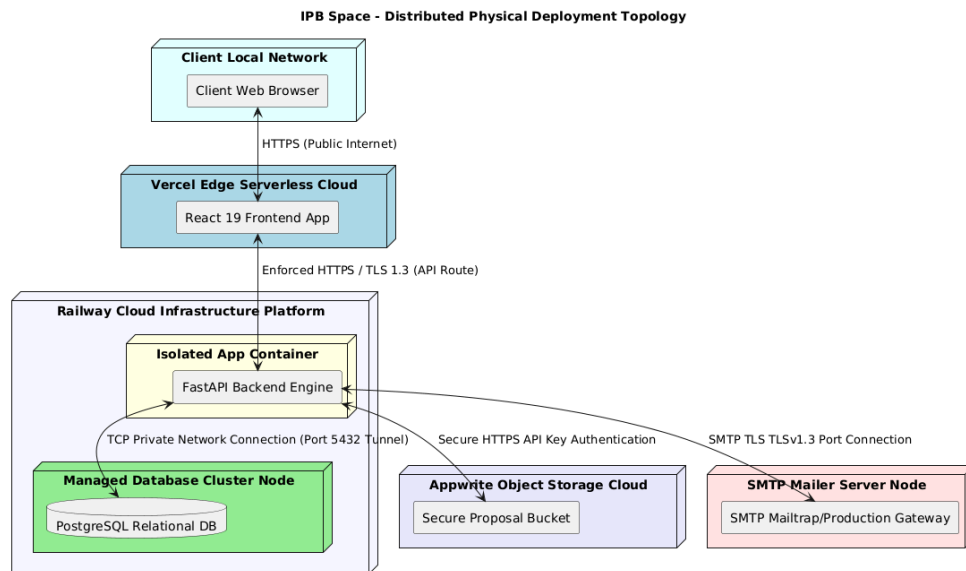
Ruang lingkup pengamanan saluran komunikasi data elektronik ini mencakup seluruh interaksi data yang terjadi di dalam ekosistem IPB Space, yang dibatasi pada:

1. Jalur komunikasi hulu antara browser internet klien pengguna menuju REST API backend server gateway.
2. Jalur komunikasi internal cloud yang menghubungkan mesin logika bisnis backend menuju kluster basis data relasional.
3. Jalur transfer objek dokumen biner menuju cluster penyimpanan cloud pihak ketiga dan instruksi interkoneksi mailer otomatis.

BAB 2: ARSITEKTUR DAN TOPOLOGI KOMUNIKASI SISTEM

2.1 Komponen Infrastruktur Aplikasi (Topologi Terdistribusi)

Arsitektur sistem informasi IPB Space dirancang dan diimplementasikan menggunakan topologi modular terdistribusi untuk memisahkan tanggung jawab operasional (*separation of concerns*) serta memperkecil permukaan serangan siber:



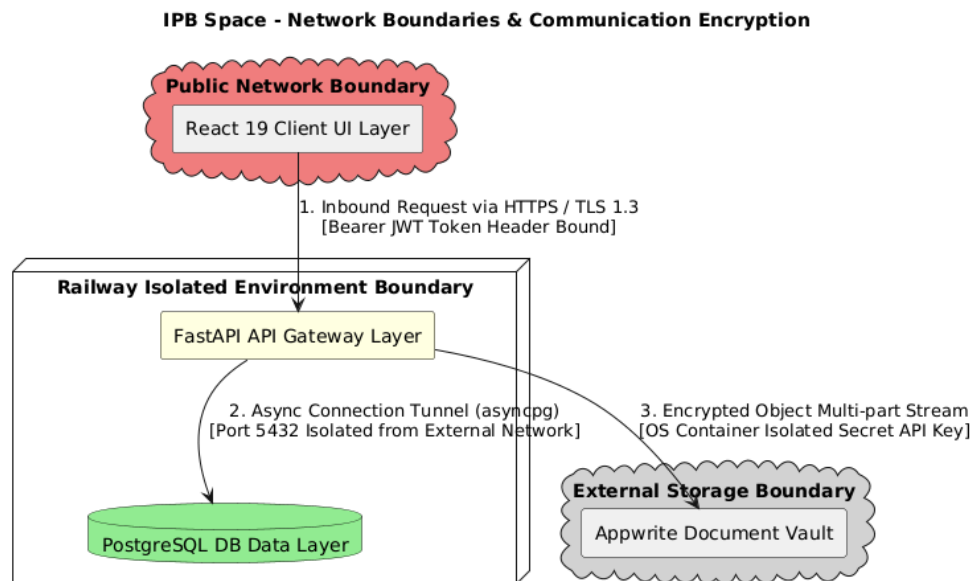
Gambar 2.1: Diagram Topologi Fisik dan Distribusi Komponen Infrastruktur Cloud IPB Space.

Berdasarkan arsitektur pada Gambar 2.1, platform mengelola lima modul komponen komputasi yang bekerja secara terintegrasi:

- **React 19 Frontend Client Client (Vercel):** Menyajikan komponen antarmuka pengguna yang ringan dan reaktif kepada civitas akademika, di-host pada jaringan global Vercel Edge Cloud.
- **FastAPI Backend Server Container (Railway):** API Gateway pusat yang mengeksekusi seluruh logika bisnis asinkron, validasi skema data payload, serta komputasi operasi kriptografi, di-host di atas container terisolasi cloud Railway.
- **PostgreSQL Database Cluster (Railway):** Cluster basis data relasional managed untuk mengunci data persisten entitas pengguna, transaksi reservasi, antrean waitlist, dan log audit forensik.
- **Appwrite Object Cloud Storage Bucket:** Penyimpanan objek terisolasi pihak ketiga yang bertindak sebagai vault aman untuk menampung data biner berkas PDF surat permohonan resmi civitas.
- **SMTP Mailer Gateway Node:** Infrastruktur server mailer asinkron untuk memproses pengiriman otomatis notifikasi surat elektronik hasil persetujuan ataupun klaim slot antrean.

2.2 Protokol Komunikasi dan Pengamanan Data dalam Perjalanan (Data in Transit)

Setiap perpindahan informasi antar-komponen diwajibkan melewati saluran terenkripsi tingkat tinggi untuk menetralsir risiko serangan penyadapan paket data rahasia (*eavesdropping*):



Gambar 2.2: Diagram Batasan Jaringan (Network Boundaries) dan Enkripsi Jalur Transmisi.

Merujuk pada perimeter Gambar 2.2, sistem menegakkan dua protokol isolasi utama untuk mengamankan data yang sedang bergerak (**Data in Transit**):

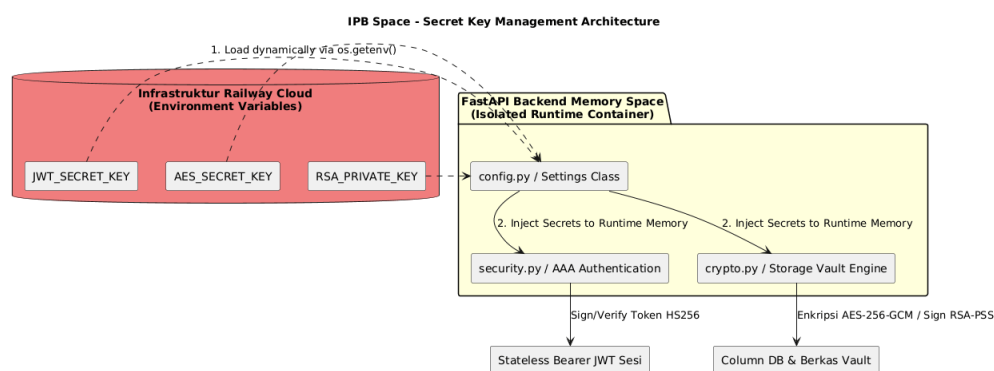
- **Komunikasi Klien ke Server via HTTPS (TLS 1.3):** Seluruh pertukaran data dari React 19 menuju REST API FastAPI diwajibkan melewati jalur terenkripsi menggunakan protokol HTTPS TLS 1.3. Enkripsi asimetris pada layer transport ini melindungi transmisi data kredensial login, data formulir, dan muatan token Bearer JWT dari ancaman serangan penyusup di tengah saluran komunikasi atau **Man-in-the-Middle (MitM)**.
- **Komunikasi Server ke Basis Data via Private Tunnel Connection:** Akses manipulasi data dari FastAPI menuju PostgreSQL diisolasi penuh di dalam internal cloud platform menggunakan string koneksi asinkron khusus (`postgresql+asyncpg://`). Port biner basis data relasional (Port 5432) dikonfigurasi secara ketat agar tertutup total dari eksposur jaringan internet eksternal dan hanya menerima request dari alamat IP internal kontainer server backend yang terdaftar dalam satu kluster.

BAB 3: PROTOKOL MANAJEMEN KUNCI DAN KRIPTOGRAFI

Untuk menjamin kepatuhan sistem terhadap prinsip keamanan tertinggi dan mencegah kebocoran parameter rahasia, platform IPB Space menerapkan arsitektur pengelolaan kunci (**secret management**) terisolasi yang memisahkan kode sumber aplikasi dari variabel lingkungan produksi cloud.

3.1 Isolasi Kunci Rahasia Sesi Informasi (.env & config.py)

Sesuai dengan instruksi laboratorium Keamanan Informasi, seluruh kunci kriptografi (**hardcoded keys**) dilarang keras ditulis secara langsung di dalam kode program repositori. Sistem IPB Space mengisolasi seluruh variabel rahasia ke dalam berkas konfigurasi lingkungan lokal bernama `.env` yang dimuat secara otomatis oleh kelas Settings pada file backend `app/core/config.py`.



Gambar 3.1: Arsitektur Manajemen Kunci Kriptografi dan Isolasi Variabel Rahasia IPB Space.

Berkas `.env` ini didaftarkan secara eksplisit ke dalam file `.gitignore` untuk mencegah ketidaksengajaan unggah berkas ke repositori publik GitHub. Prosedur penarikan rahasia dari Gambar 3.1 diatur secara dinamis melalui parameter berikut:

- `SECRET_KEY`: String acak berkekuatan entropi tinggi yang digunakan sebagai kunci rahasia simetris untuk menandatangani dan memverifikasi token sesi JWT menggunakan algoritma HS256.
- `AES_SECRET_KEY`: Kunci simetris 256-bit rahasia untuk memicu modul enkripsi data at rest tingkat kolom dan berkas proposal.
- `RSA_PRIVATE_KEY`: Pasangan kunci asimetris tingkat server untuk membubuhkan tanda tangan digital pada tiket QR code civitas.

3.2 Protokol Manajemen Kunci Enkripsi Kolom AES-256

Proses enkripsi tingkat kolom (*Column-Level Encryption*) pada skema tabel database PostgreSQL (`users` dan `facilities`) menggunakan kunci simetris berbasis algoritma AES-256-GCM. Kunci ini dikelola langsung di sisi memori server backend FastAPI tanpa pernah menyentuh persistent storage dalam bentuk plaintext. Server backend bertindak sebagai entitas tunggal (**Single Source of Truth**) yang memegang otoritas untuk memanggil fungsi enkripsi sebelum penulisan ke disk database (*Encryption at Rest*).

3.3 Manajemen Kunci Hashing Kredensial Pengguna (Password Hashing)

Kata sandi pengguna wajib dilindungi menggunakan fungsi satu arah kriptografi menggunakan algoritma Bcrypt (dikonfigurasi melalui `pwd_context` di file backend `app/core/security.py`). Proses penyerpihan otomatis (*Salting*) yang bersumber dari generator acak aman sistem operasi

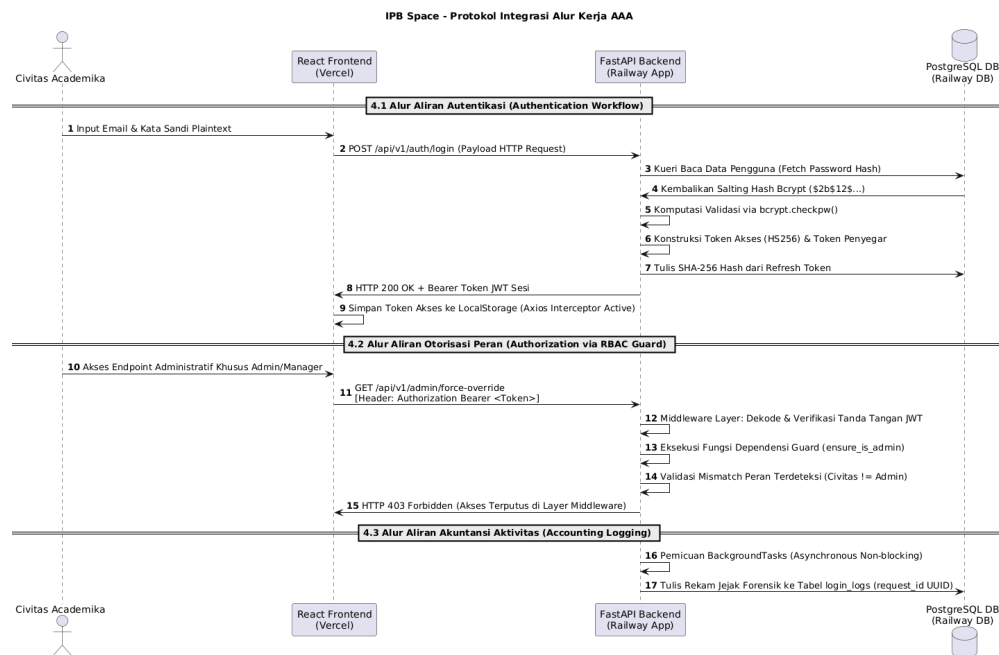
diterapkan untuk menghasilkan string hash yang unik, sehingga database kebal terhadap ancaman pembongkaran berbasis serangan **Rainbow Table** jika terjadi kebocoran basis data.

BAB 4: INTEGRASI ALUR KERJA PROTOKOL AAA (ALUR UTAMA)

Kerangka kerja protokol **Authentication, Authorization, dan Accounting** (AAA) diintegrasikan secara linear di dalam alur kerja utama aplikasi untuk mengontrol pergerakan hak akses aktor dari hulu ke hilir.

4.1 Visualisasi Runtunan Aliran Protokol AAA Terintegrasi

Uji alur integrasi protokol AAA digambarkan melalui skenario diagram urutan (**sequence diagram**) antarkomponen berikut:



Gambar 4.1: Diagram Urutan (Sequence Diagram) Integrasi Alur Kerja Protokol AAA IPB Space.

4.2 Alur Aliran Autentikasi (Authentication Workflow)

Berdasarkan rincian Fase 1.0 pada Gambar 4.1, proses verifikasi identitas civitas dijalankan melalui mekanisme **Bearer Token Validation**:

1. Pengguna menginput kombinasi email resmi dan kata sandi pada halaman login React 19 frontend.
2. Data dikirimkan melalui saluran aman HTTPS menuju endpoint `/api/v1/auth/login` di backend FastAPI.
3. Backend memeriksa validitas kredensial dengan mencocokkan password hash menggunakan fungsi `bcrypt.checkpw()`. Jika sesuai, fungsi `create_access_token` akan menghasilkan string JSON Web Token (JWT) yang memuat klaim identitas (`sub`), peran (`role`), dan waktu kedaluwarsa token.
4. Demi menjaga keamanan dari risiko pembajakan sesi, sistem memproses token penyegar (**Refresh Token**) dengan mengubahnya menjadi format hash satu arah **SHA-256** sebelum disimpan ke database, sehingga token refresh asli tidak terekspos plaintext di tabel `user_sessions`.
5. Token dikembalikan ke klien untuk disimpan pada LocalStorage dan otomatis dilampirkan pada header `Authorization: Bearer <token>` menggunakan **Axios Interceptors** pada setiap request kueri berikutnya.

4.3 Alur Aliran Otorisasi Peran (Authorization via RBAC Guard)

Pembatasan hak akses menu diintegrasikan langsung pada rute API menggunakan injeksi dependensi FastAPI fungsional pada file `app/api/dependencies.py` (Fase 2.0 Gambar 4.1):

1. Setiap endpoint fungsional diproteksi oleh fungsi dependensi `get_current_user` yang bertugas mendekode dan memverifikasi tanda tangan digital token JWT.
2. Sistem mengimplementasikan utilitas kustom kelas `RoleChecker` yang ditanam pada rute API administratif. Jika klaim token pengguna mengekstrak data role berstatus `civitas`, sementara endpoint tersebut mendefinisikan batas minimum hak akses peran `super_admin` (seperti rute `Force Override`), sistem otomatis memotong alur kerja di tingkat middleware dan mengembalikan respon kesalahan HTTP 403 Forbidden untuk mencegah kerentanan eskalasi hak akses objek.

4.4 Alur Aliran Akuntansi Aktivitas (Accounting & System Audit Log)

Setiap keputusan operasional kritis yang dieksekusi pada `app/services/booking_service.py` wajib memicu pencatatan akuntansi permanen (Fase 3.0 Gambar 4.1):

- **Dual-Layer Log Execution:** Sistem secara otomatis menangkap data identitas aktor yang lolos dari fungsi otorisasi, mendelegasikan perintah lewat fungsi **BackgroundTasks** FastAPI agar bekerja secara asinkron (**non-blocking**).
- Log makro dialirkan tanpa cache menggunakan parameter `PYTHONUNBUFFERED=1` langsung menuju file `app_logs.txt` untuk konsumsi performa grafik admin, sedangkan log mikro forensik (mencakup data alamat IP Address, penanda waktu milidetik, jenis OS, dan jenis aktivitas) dituliskan secara langsung ke dalam tabel database relasional `login_logs` PostgreSQL. Rantai audit diikat menggunakan UUID kustom lintas layer untuk memastikan sifat log adalah **immutable** (tidak dapat dimanipulasi).

BAB 5: RANCANGAN TANDA TANGAN DIGITAL DAN OFFLINE VERIFICATION

Sistem IPB Space mengimplementasikan fitur tanda tangan digital (**Digital Signature**) berbasis kriptografi asimetris menggunakan algoritma **RSASSA-PSS** dengan panjang kunci **RSA 2048-bit** untuk menjamin pilar integritas dan nir-sangkal (**non-repudiation**) pada tiket digital pemesanan ruangan.

5.1 Dasar Kriptografi RSASSA-PSS

Pemilihan skema probabilistik PSS (Probabilistic Signature Scheme) memberikan lapis pertahanan yang jauh lebih tangguh terhadap ancaman serangan siber jika dibandingkan dengan skema konvensional PKCS#1 v1.5. Aturan matematis dan parameter biner yang dikonfigurasi pada sistem meliputi:

- **Panjang Kunci:** Kunci privat server berukuran 2048-bit untuk operasi penandatanganan hulu, dan kunci publik 2048-bit untuk operasi verifikasi hilir.
- **Cryptographic Hash:** Menggunakan fungsi ringkasan **SHA-256** untuk memproses string teks transaksi menjadi sidik jari digital berukuran tetap (256-bit).
- **Salt Randomization:** Mengintegrasikan mekanisme salt dinamis internal pada padding PSS selama proses enkripsi asimetris berlangsung, memastikan output string tanda tangan selalu bersifat unik dan reproduibel secara aman.

5.2 Alur Penerbitan Tiket Digital QR Code

Proses penandatanganan data reservasi dieksekusi secara otomatis di dalam memori server backend FastAPI melalui tahapan prosedural berikut:

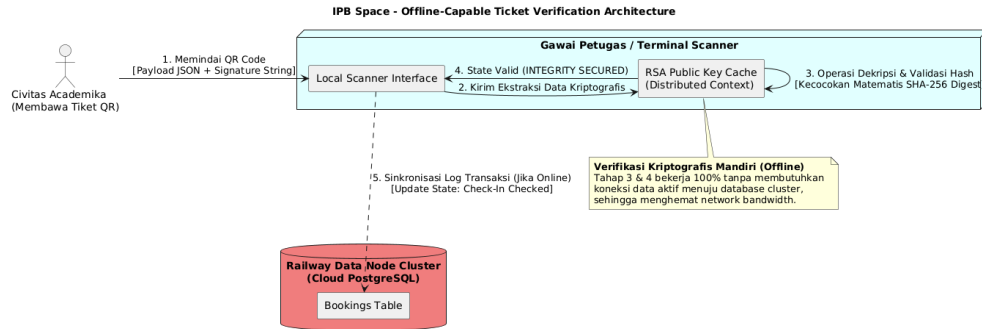
1. **Konstruksi Payload:** Data manifes reservasi dikompilasi ke dalam objek JSON terstruktur (memuat atribut `booking_id`, `user_id`, `facility_id`, dan `date_of_booking`).
2. **Deterministic Serialization:** Objek JSON diserialisasi menjadi biner teks menggunakan aturan pengurutan kunci (`sort_keys=True`) guna memastikan integritas string biner tidak berubah:
3. **Cryptographic Signing:** Backend meringkas pesan M menggunakan SHA-256, kemudian menandatangani menggunakan Kunci Privat RSA server:

$$S = \text{RSA-Sign}(K_{\text{private}}, \text{PSS-Padding}(\text{SHA-256}(M)))$$

4. **String Token Construction:** Output signature bures terenkripsi dikonversi menjadi format string URL-Safe Base64, kemudian digabungkan dengan payload utama menggunakan separator titik (`.`), menghasilkan satu token string tunggal untuk dirender menjadi gambar biner QR Code tiket.

5.3 Alur Verifikasi Sisi Lapangan (Offline-Capable Verification)

Mekanisme validasi check-in fisik di lapangan dirancang untuk dapat bekerja secara mandiri tanpa harus memicu pemanggilan kueri database secara konstan (**Offline-Capable**):



Gambar 5.1: Arsitektur Validasi Tiket Digital QR Code Berbasis RSA-PSS (Offline-Capable).

Sesuai dengan mekanisme arsitektur pada Gambar 5.1, proses verifikasi data di lapangan berjalan melalui 4 fase esensial:

1. Ketika QR Code dipindai oleh gawai petugas, token string akan dipecah kembali menjadi komponen payload JSON dan string signature (S).
2. Komponen penverifikasi mengekstrak Kunci Publik RSA server ($SIGNING_PUBLIC_KEY$) yang telah terdistribusi atau tersimpan di dalam cache lokal gawai.
3. Operasi verifikasi kriptografis dijalankan langsung secara lokal di dalam ruang memori runtime gawai scanner:

$$H_{\text{decrypted}} = \text{RSA-Verify}(K_{\text{public}}, S)$$

4. Sistem membandingkan nilai $H_{\text{decrypted}}$ dengan kalkulasi ulang hash SHA-256 dari teks JSON aktual. Jika hasil komputasi bernilai cocok, maka status integritas dan keaslian tiket digital terkonfirmasi sah (**PASSED**). Langkah validasi matematis awal ini sama sekali tidak memerlukan koneksi jaringan internet aktif menuju kluster basis data relasional, menghemat bandwidth jaringan secara masif.

BAB 6: MATRIKS KRITERIA PENERIMAAN (ACCEPTANCE CHECKLIST)

Sebelum platform IPB Space dideploy secara penuh ke lingkungan produksi cloud Vercel dan Railway, seluruh komponen pengerasan kontrol keamanan wajib melewati pengujian ambang batas pemenuhan kriteria berikut:

Domain Uji	Kriteria Kepatuhan Penerimaan Sistem	Status	Target
Authentication	Kata sandi wajib disimpan menggunakan enkripsi hash Bcrypt 12 putaran. Tidak ada eksposur teks terang pada log sistem.	✓	Wajib
Authentication	Ambang batas kesalahan login dikunci maksimal 5 kali percobaan, memicu isolasi Account Lockout selama 15 menit.	✓	Wajib
Authentication	Sesi stateless token JWT berumur pendek (Access Token 30 menit) dan refresh token di-hash SHA-256 di database.	✓	Wajib
Authorization	Pemisahan tugas kaku via RBAC (Civitas, Manager, Admin). Setiap request rute API divalidasi ketat oleh server middleware.	✓	Wajib
Authorization	Mitigasi celah IDOR diimplementasikan melalui Owner Validation pada fungsi pembatalan reservasi.	✓	Wajib
Accounting	Setiap aktivitas transaksi diikat menggunakan request_id (UUID v4) untuk menjamin rantai investigasi forensik.	✓	Wajib
Accounting	Akses menuju Log Audit Sistem diisolasi secara mutlak dan hanya dapat dipanggil oleh peran Super Admin via rute API.	✓	Wajib
Data Protection	Data sensitif PII (NIK dan Nomor HP) dilindungi menggunakan enkripsi tingkat kolom (Column-Level Encryption) AES-256-GCM.	✓	Wajib
Data Protection	Ekstraksi file .env terisolasi penuh dari repositori publik Git melalui penulisan aturan ketat di berkas .gitignore.	✓	Wajib
Data Protection	Seluruh port biner kluster database PostgreSQL (Port 5432) tertutup dari luar dan hanya menerima IP internal server API.	✓	Wajib
Digital Signature	Operasi pembuatan tanda tangan digital QR code menggunakan sorting key objek JSON untuk menjamin sifat deterministik.	✓	Wajib

Digital Signature	Mekanisme offline verification tiket digital sukses dijalankan menggunakan kunci publik server tanpa akses kueri DB.	✓	Wajib
OWASP Testing	Kueri manipulasi SQL Injection terbukti lumpuh total melalui implementasi parameterized queries ORM SQLAlchemy.	✓	Wajib